

INSEGUS

PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

UNIVERSIDAD D SEVILLA
1505

PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

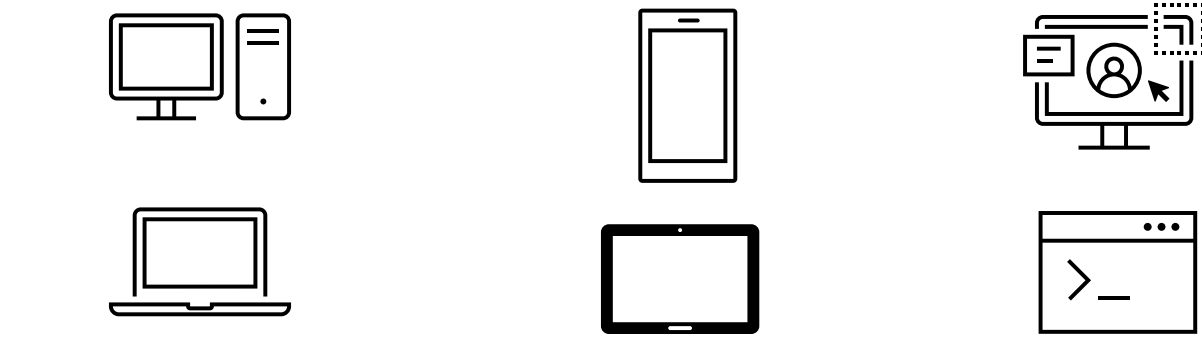
Índice

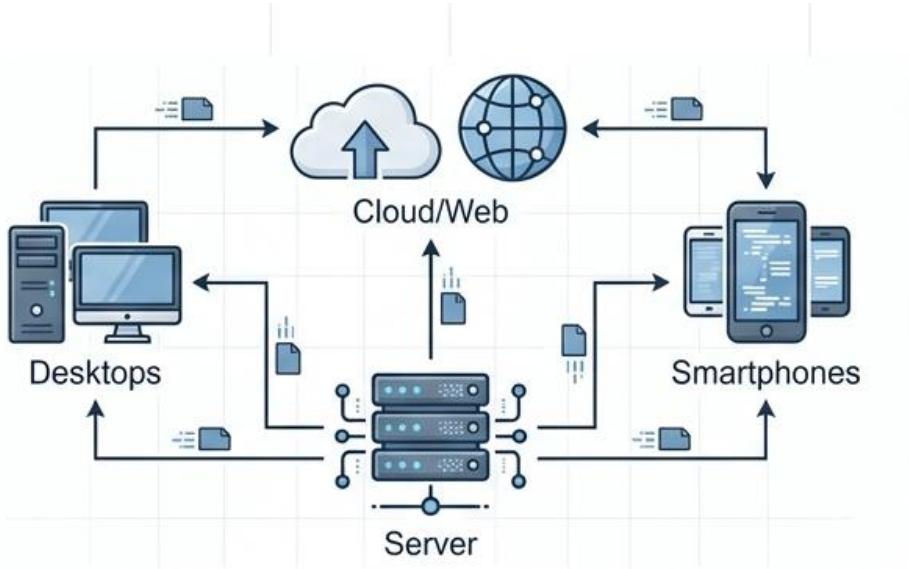
1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Contexto

1. Sistemas Físicos	2. Movilidad	3. Aplicaciones Web
Equipos de sobremesa, portátiles y servidores.	Dispositivos móviles corporativos de los usuarios.	Plataformas transaccionales que dan soporte a las actividades del cliente.





PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Contexto

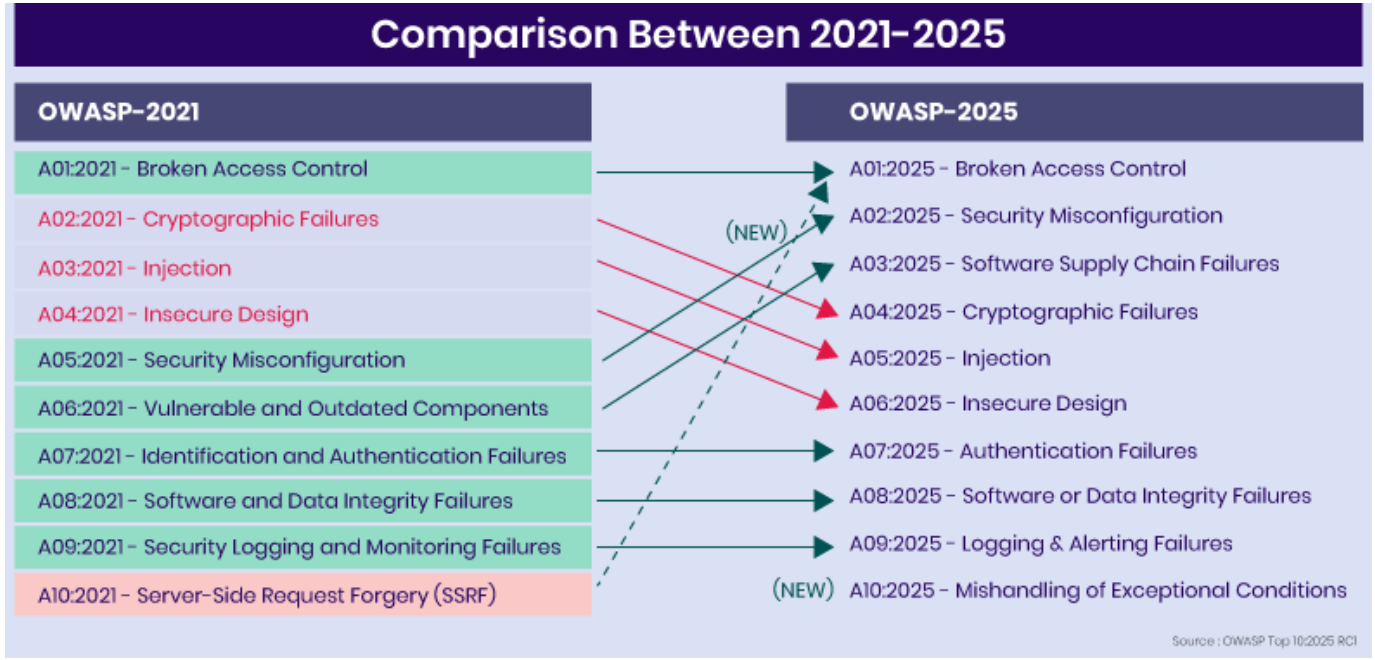


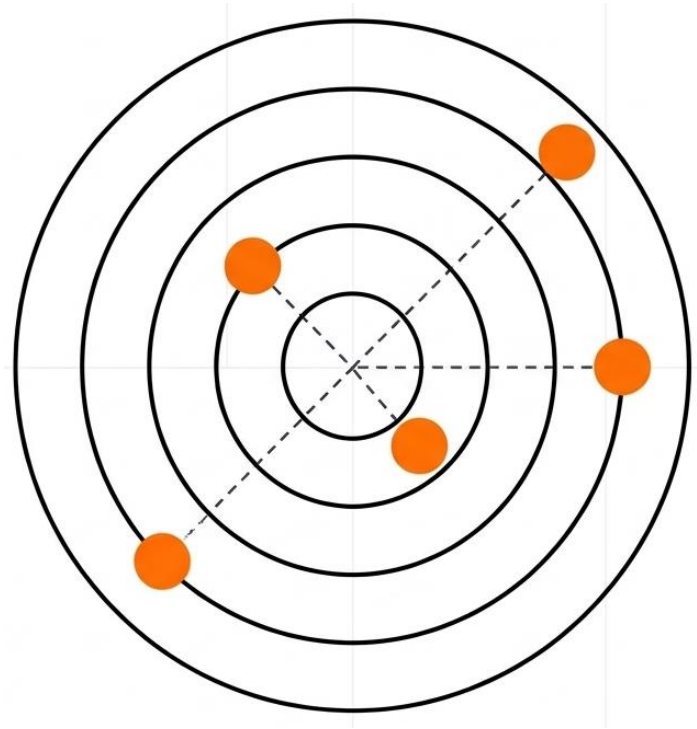
PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

Problemas de seguridad





PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

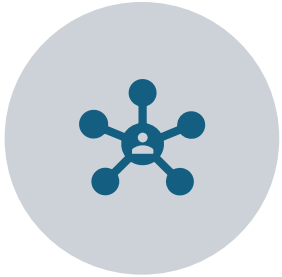
Objetivos



Intercepción y Trazabilidad de Tráfico Cifrado HTTPS: Desplegar y configurar un proxy interceptor (OWASP ZAP / Burp Suite) demonstrando la trazabilidad de tráfico http/https a través de dicho proxy.



Auditoría y Bastionado (Hardening) de Endpoints: Auditoría de seguridad de los endpoints (sistemas informáticos de sobremesa, portátiles y dispositivos móviles) que utilizan los usuarios de los usuarios PDI, Estudiantes, y PTGAS de la Universidad para determinar su postura de seguridad.



Pentesting Web y Fuzzing Automatizado (OWASP Top 10): Auditoría de las aplicaciones Web que dan soporte a las actividades de la universidad pública, identificando posibles vulnerabilidades de seguridad, tales como Inyecciones, XSS, CSRF, Path Traversal, etc.

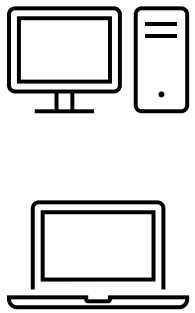


Generación de Evidencias Técnicas: realizar las pruebas y capturar las evidencias de las auditorías realizadas.

PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Auditoría y Bastionado (Hardening) de Endpoints

Obtener el índice de hardening que tiene el equipo informático de sobremesa concreto y realizar las acciones correspondientes para alcanzar el índice de hardening requerido por la Política de Seguridad de la empresa cliente



```
Follow-up:
----------------------------
- Show details of a test (lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

================================================================================

Lynis security scan details:

Hardening index : 53 [##########          ]
Tests performed : 214
Plugins enabled : 1

Components:
- Firewall               [V]
- Malware scanner        [X]

Lynis Modules:
- Compliance Status      [?]
- Security Audit         [V]
- Vulnerability Scan     [V]

Files:
- Test and debug information      : /var/log/lynis.log
- Report data                     : /var/log/lynis-report.dat

================================================================================
```

Aplicar la correspondiente auditoría para alcanzar el hardening index especificado en la Política de Seguridad (no inferior a 70), mediante las correspondientes actuaciones que tienen que ser todas documentadas en el informe final de este proyecto



PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Análisis de navegadores web

El objetivo de esta actuación es analizar y fortificar los navegadores web presentes en los sistemas informáticos. Se definirá e implementará un conjunto de directivas corporativas de bastionado (browser hardening)



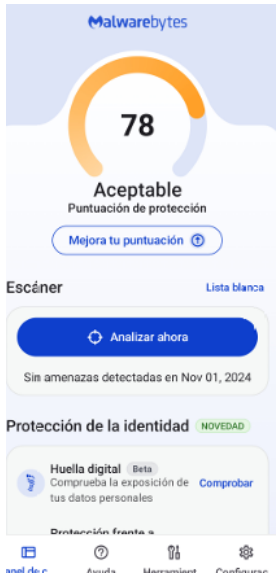
PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Análisis de un sistema móvil

El objetivo prioritario es determinar la postura de seguridad del dispositivo BYOD del usuario (PDI / PTGAS) y ejecutar las acciones correctoras necesarias para alcanzar el nivel de bastionado (hardening).





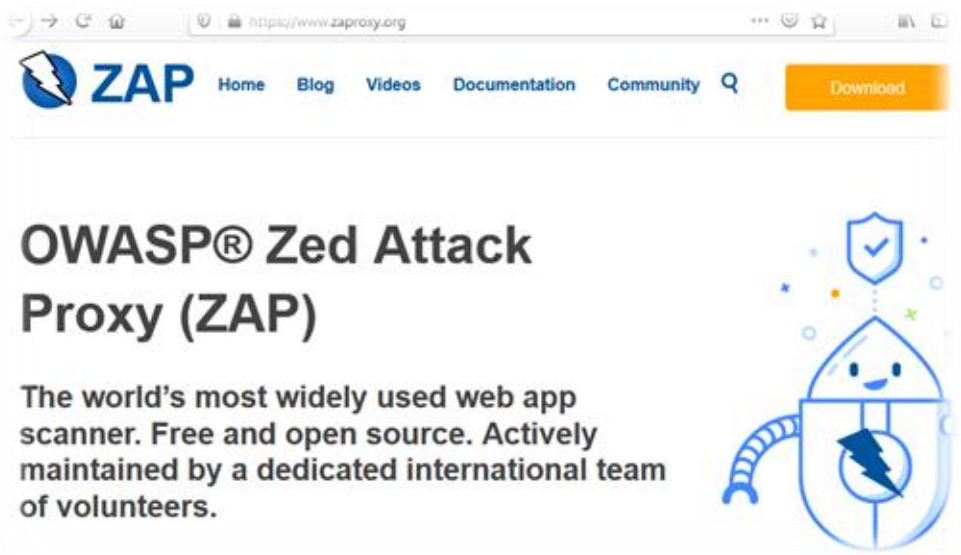




PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Pentesting Web y Fuzzing Automatizado

Debe presentar un conjunto de pruebas que muestre las posibilidades de una para comprobar la correcta trazabilidad de las peticiones HTTP/HTTPS sin modificación alguna de los parámetros de las peticiones y las respuestas obtenidas desde el servidor de prueba

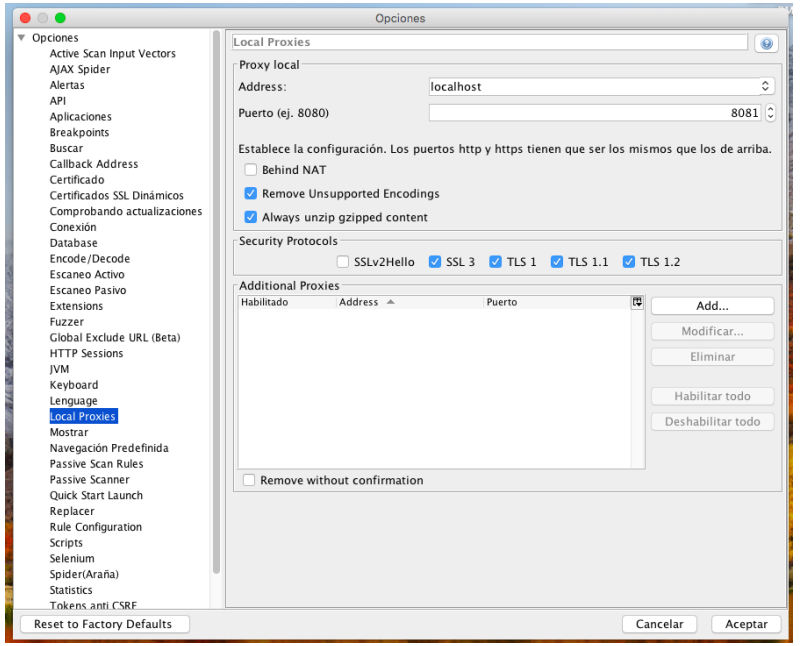




PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Pentesting Web y Fuzzing Automatizado

- Herramientas Dynamic Application Security Testing (**DAST**) que usan la metodología de testing de seguridad de caja-negra
- **OWASP ZAP** es un marco de trabajo para la trazabilidad de peticiones/respuestas HTTP/HTTPS y analizar posibles vulnerabilidades de las aplicaciones web
- Para poder **interceptar el tráfico** (peticiones/respuestas) en la herramienta en la pestaña "Proxy" tendremos que configurar los siguientes aspectos
    - ***Address: dirección IP de escucha (localhost)***
    - ***Port: puerto de escucha (8081)***

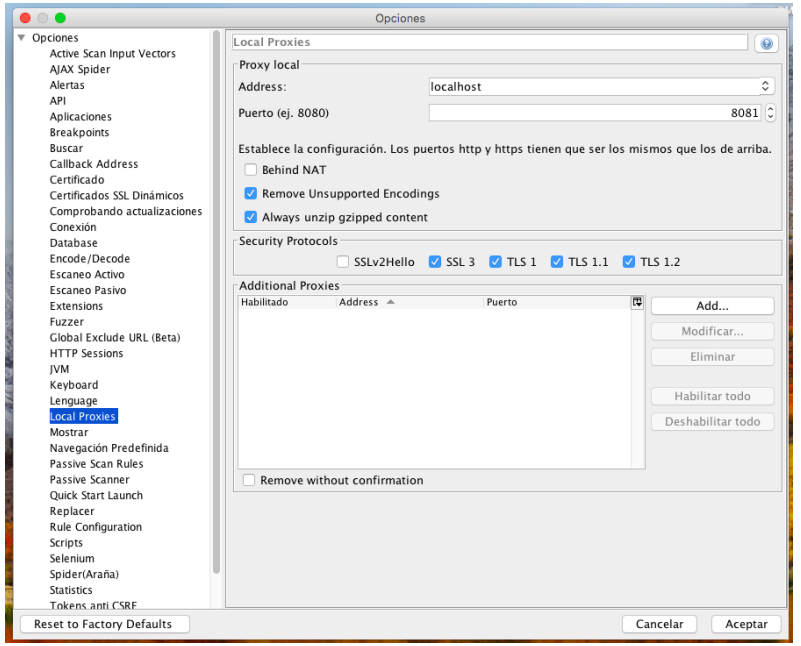




PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Pentesting Web y Fuzzing Automatizado

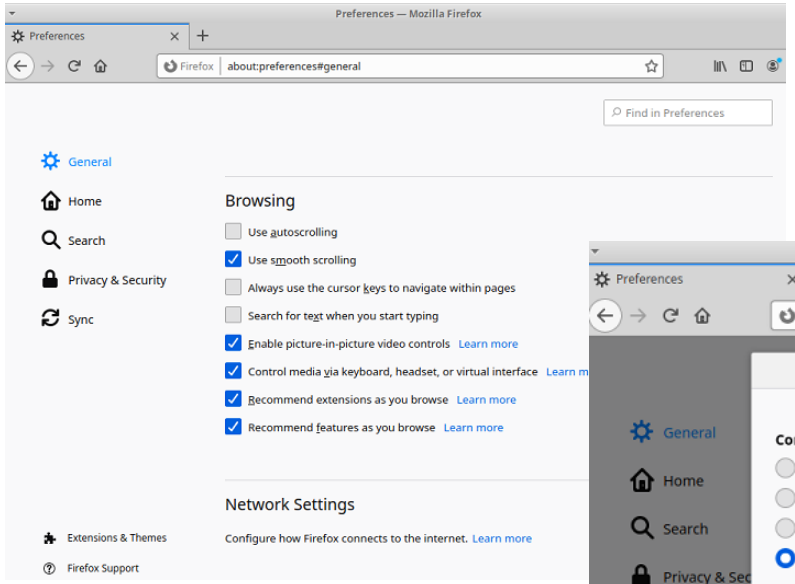
- Herramientas Dynamic Application Security Testing (**DAST**) que usan la metodología de testing de seguridad de caja-negra
- **OWASP ZAP** es un marco de trabajo para la trazabilidad de peticiones/respuestas HTTP/HTTPS y analizar posibles vulnerabilidades de las aplicaciones web
- Para poder **interceptar el tráfico** (peticiones/respuestas) en la herramienta en la pestaña "Proxy" tendremos que configurar los siguientes aspectos
    - ***Address: dirección IP de escucha (localhost)***
    - ***Port: puerto de escucha (8081)***

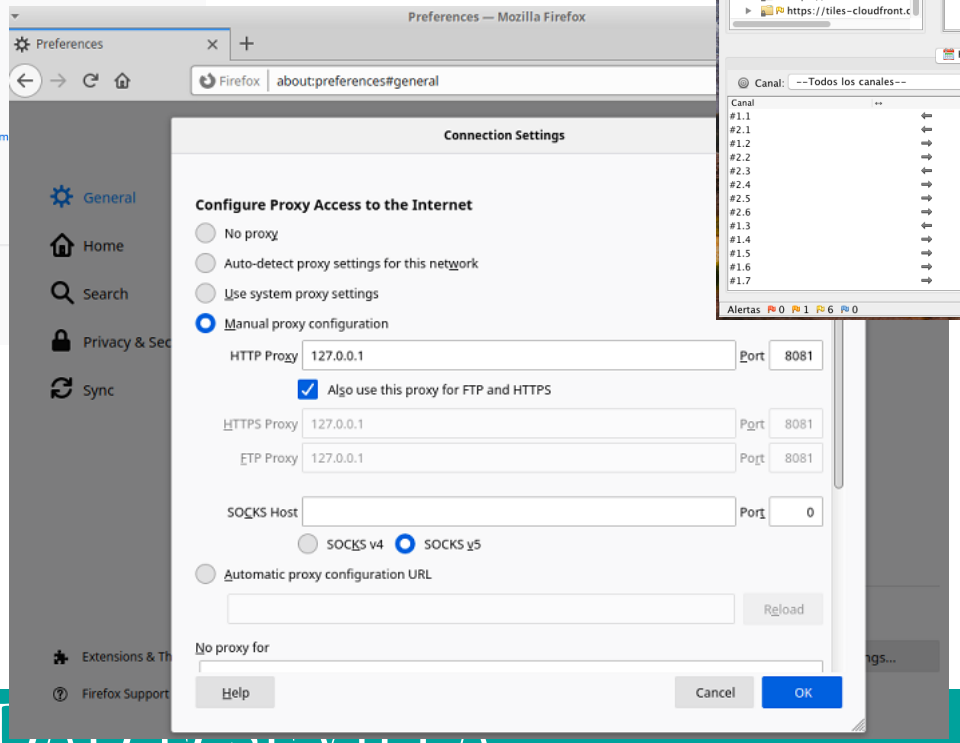


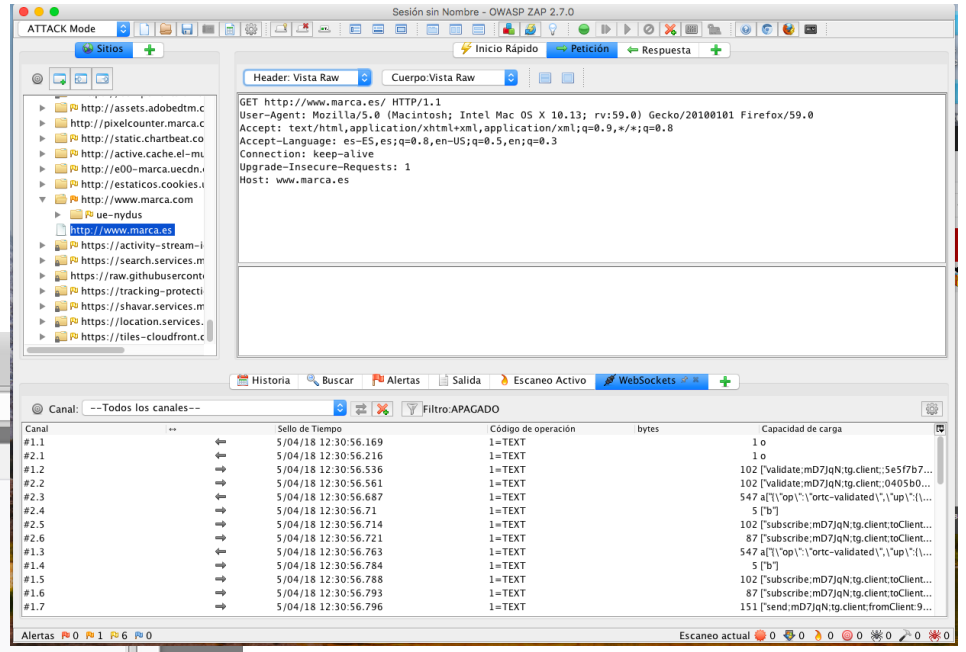


PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Pentesting Web y Fuzzing Automatizado

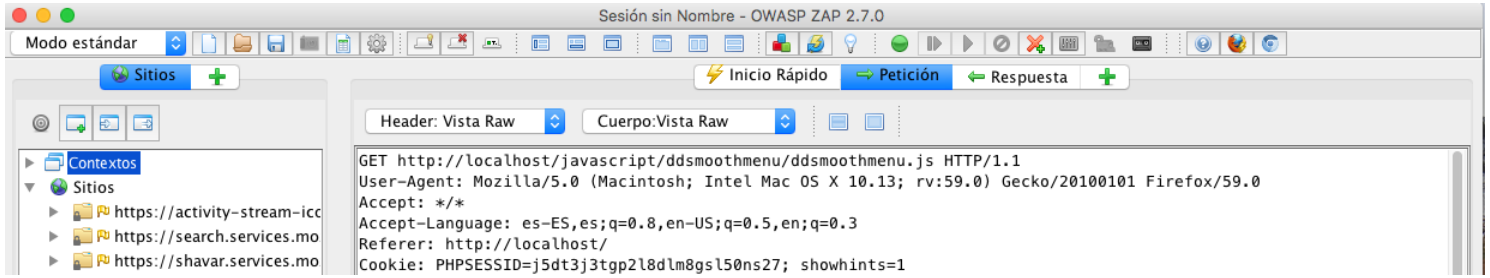






Modo intercepción de peticiones con OWASP ZAP

- Es posible activar un modo especial de ejecución donde capturaremos las peticiones y antes de ser respondidas por el servidor podremos visionar la petición incluso modificarla y reenviarla al servidor modificadas
- Este es un caso de ejemplo de Man-in-the-Middle (**MitM**)
- Para activar el modo de intercepción sólo tenemos que activar un "**Breakpoint**", desde el botón verde situado en la barra de menús de ZAP



- Una vez activada dicha opción ZAP se pondrá en modo recepción de peticiones y podremos capturar peticiones
- También podremos editar las peticiones y cambiar valores

PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Pentesting Web y Fuzzing Automatizado

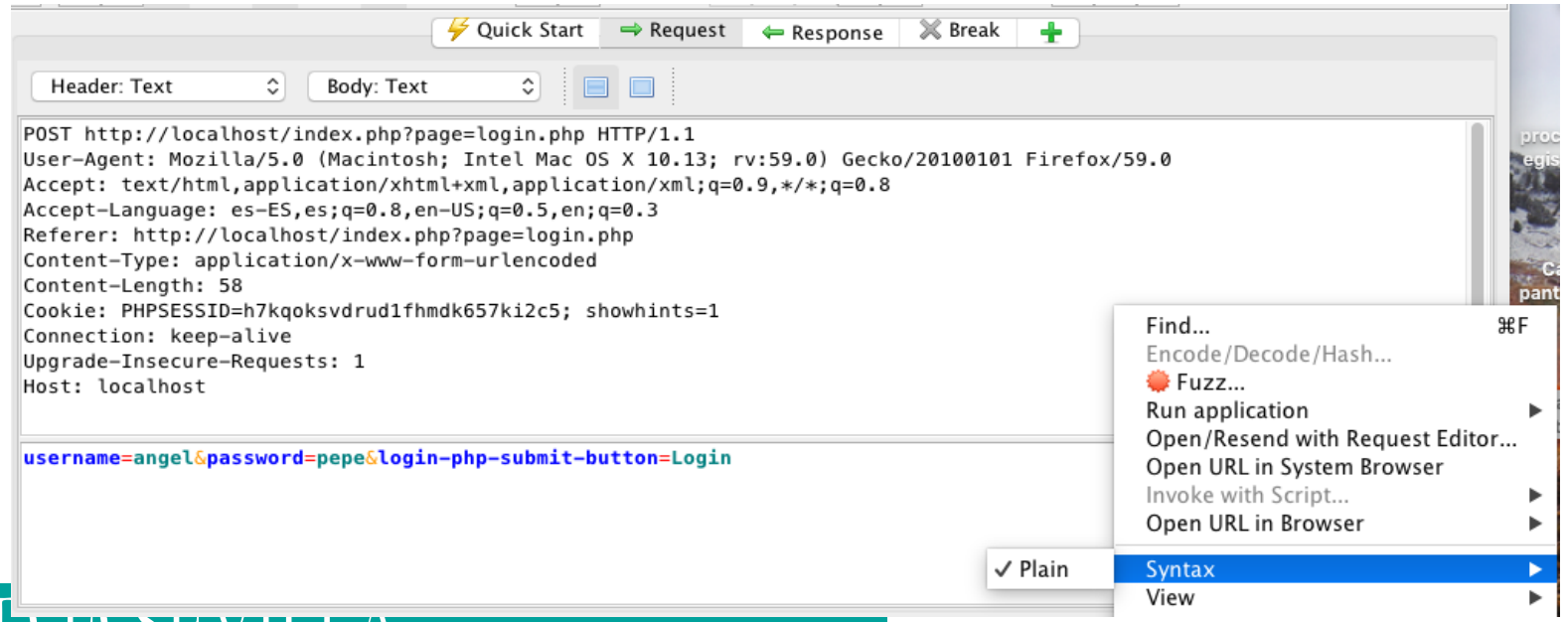
El objetivo será **seleccionar una aplicación web y realizar una auditoría para determinar potenciales vulnerabilidades,** y presentar las pruebas que permitan determinar las potenciales vulnerabilidades explotables de al menos 3 de las recomendadas por OWASP Top 10.



Pentesting Web y Fuzzing Automatizado

Modo testeo de inyecciones con OWASP ZAP

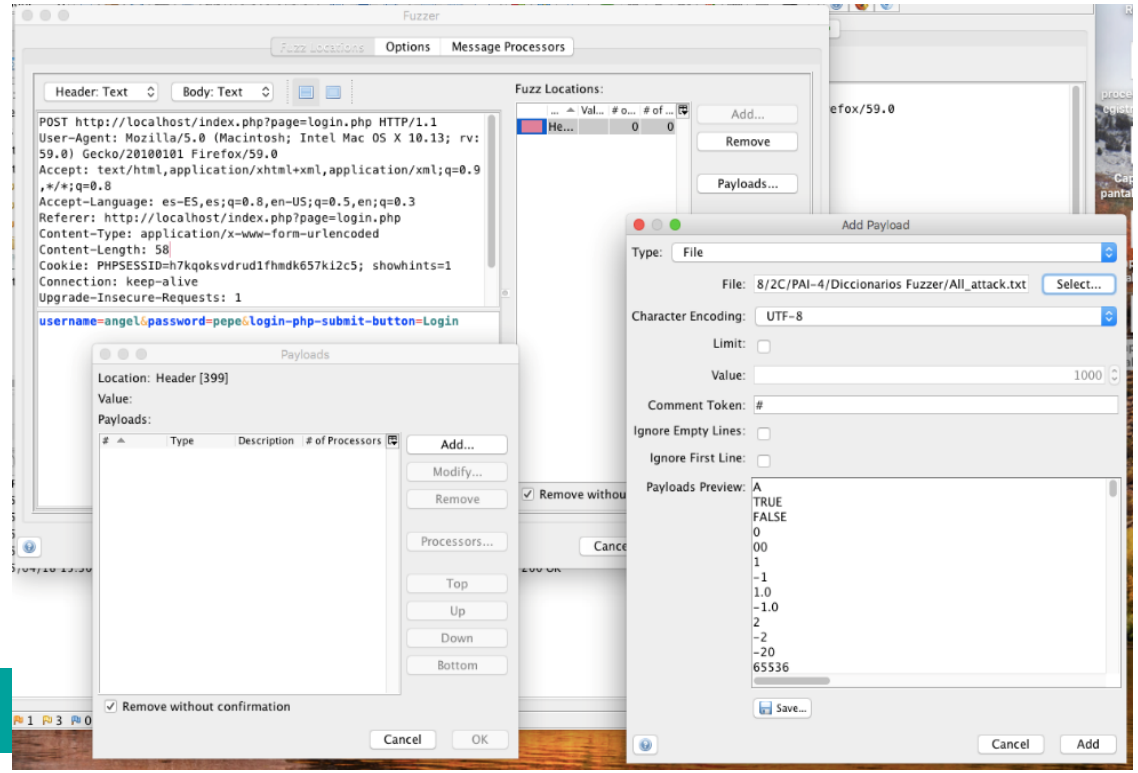
- Para realizar las pruebas de inyección no es necesario probar uno a uno las diferentes cadenas/payloads
- OWASP ZAP está provisto de un "**Fuzzer**" que permite una vez interceptada una petición, repetir la misma con diferentes parámetros de entrada
- Para ello sobre cualquier petición "Request" que disponga de parámetros le damos botón derecho y tenemos la opción "Fuzz"



Pentesting Web y Fuzzing Automatizado

Modo testeo de inyecciones con OWASP ZAP

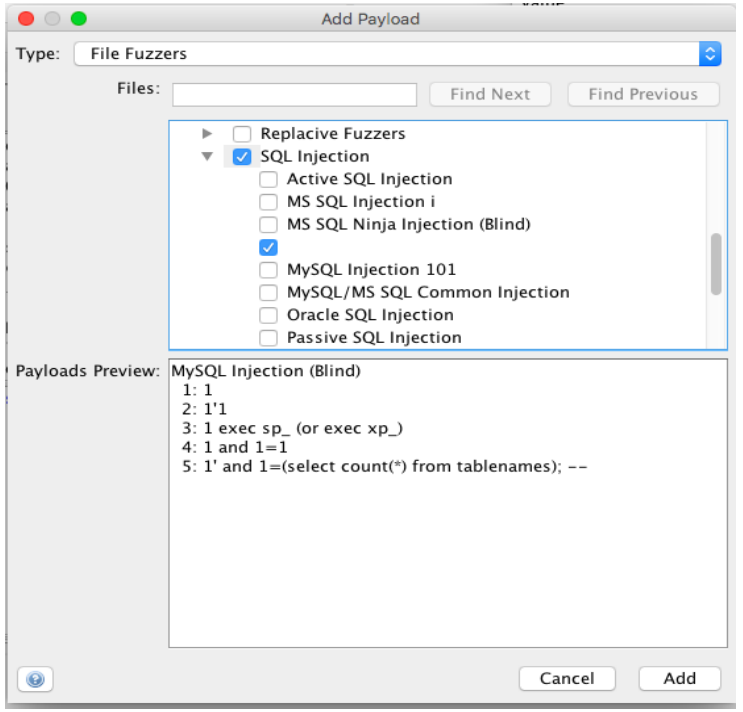
- El **Fuzzer** nos permitirá configurar que parámetros usaremos para introducir las diferentes cadenas de búsqueda para probar en las peticiones



Pentesting Web y Fuzzing Automatizado

Modo testeo de inyecciones con OWASP ZAP

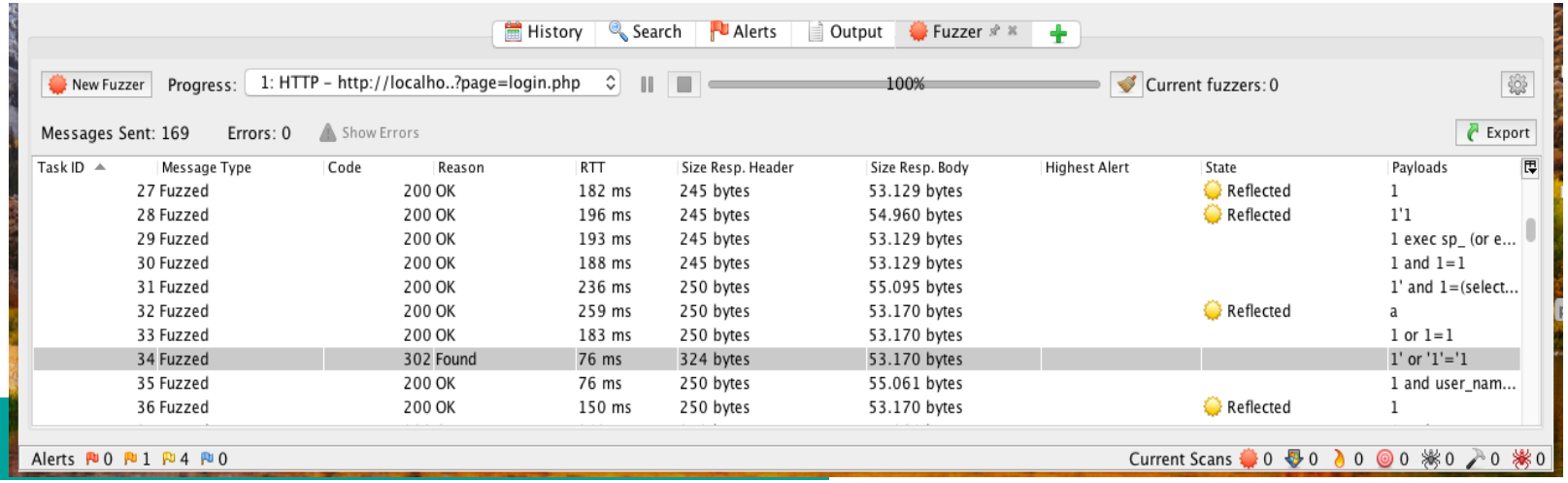
- También ZAP viene provisto con un conjunto de diccionarios de payloads precargados para hacer pruebas de inyecciones
- Marcamos la opción de "File Fuzzer"
- Dentro de la opción de "jbrofuzz" tenemos una sección de "SQL Injection" y dentro tenemos varios diccionarios de payloads predefindos



Pentesting Web y Fuzzing Automatizado

Modo testeo de inyecciones con OWASP ZAP

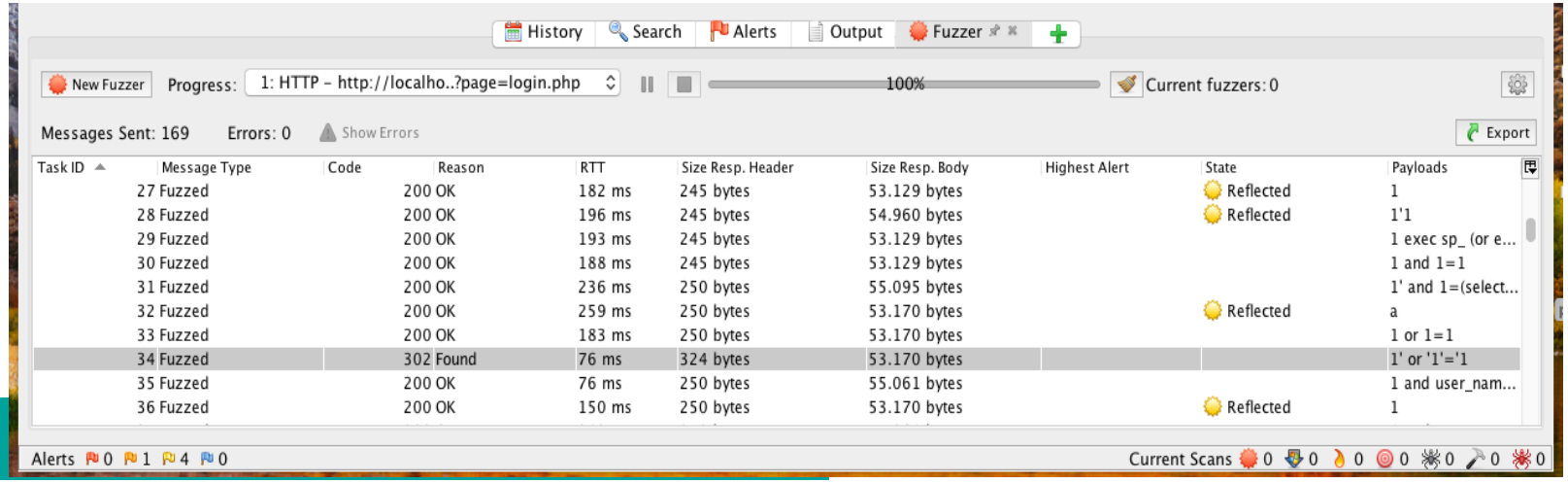
- El Fuzzer se encargará de usar todas las cadenas del diccionario que hayamos introducido y tomar las respuestas, mostrándonos una pantalla de resultados
- Será trabajo nuestro identificar qué peticiones han dado resultados satisfactorios y ver qué cadenas son las más interesantes
- Todas aquellas peticiones marcadas como “Reflected” en su “Status” o como “Found” en su “Reason” son peticiones interesantes por sus resultados



Pentesting Web y Fuzzing Automatizado

Modo testeo de inyecciones con OWASP ZAP

- El Fuzzer se encargará de usar todas las cadenas del diccionario que hayamos introducido y tomar las respuestas, mostrándonos una pantalla de resultados
- Será trabajo nuestro identificar qué peticiones han dado resultados satisfactorios y ver qué cadenas son las más interesantes
- Todas aquellas peticiones marcadas como “Reflected” en su “Status” o como “Found” en su “Reason” son peticiones interesantes por sus resultados



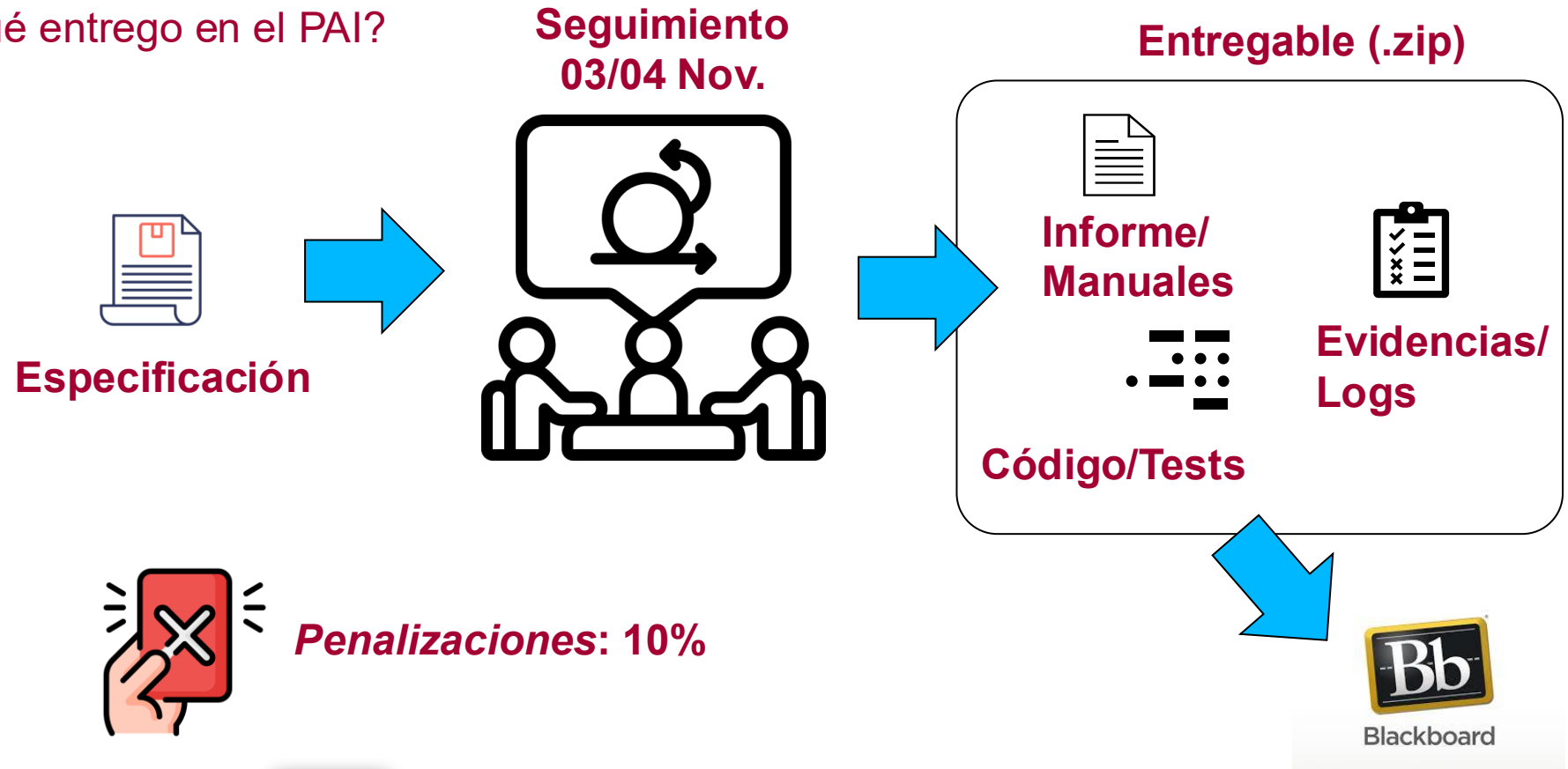
PA-3. VULNAWEB. AUDITORÍA DE SEGURIDAD EN SISTEMAS INFORMÁTICOS Y ANÁLISIS DE VULNERABILIDADES EN UNA UNIVERSIDAD PÚBLICA

Índice

1. Contexto
2. Problemas de seguridad
3. Objetivos y requisitos
4. Entrega

Entrega

¿Cómo y qué entrego en el PAI?



***Penalizaciones*: 10%**

Deadline: 10 de noviembre



UNIVERSIDAD
D SEVILLA
1505